How to distribute containers compliantly

Caren Kresse
Open Source Automation Development Lab (OSADL) eG
C.Kresse@osadl.org

How is a container image made up?

- Stacked layers that contain different components, functionalities and modifications.

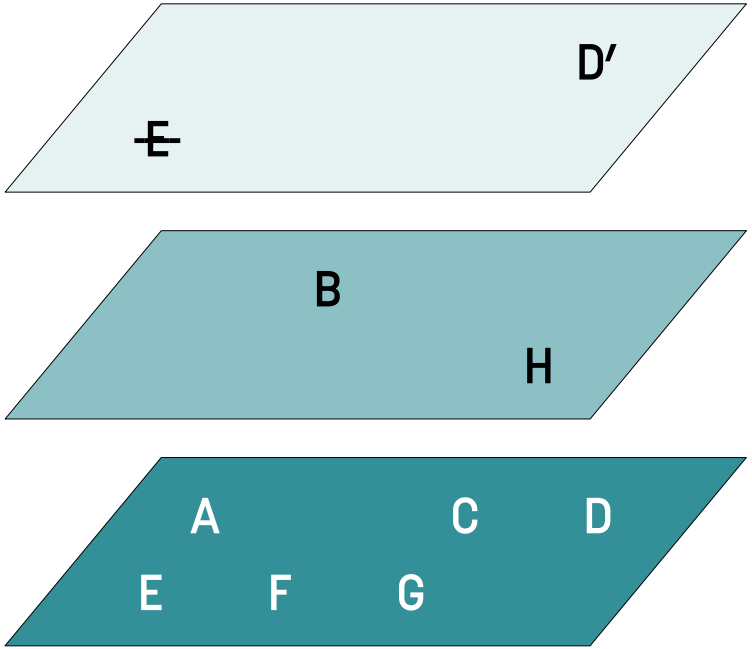
How is a container image made up?

- Stacked layers that contain different components, functionalities and modifications.
- For example:

Layer 3: Customization	→	Removal and modification of components
Layer 2: Application	→	Applications and their libraries
Layer 1: Base layer	→	System requirements: C library, package manager, shell …

How is a container image made up?

- For example:



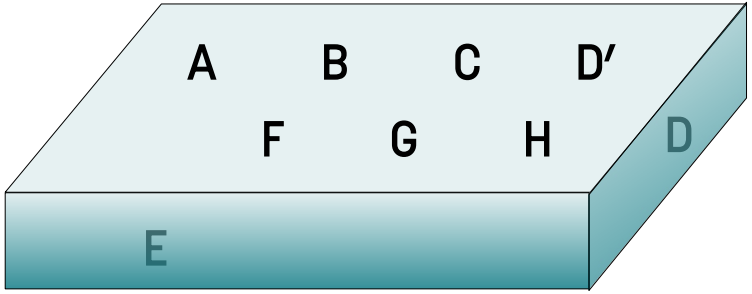
→ Layer 3: Remove file E and modify file D

→ Layer 2: Add files B and H

→ Layer 1: Base image

What does the resulting container look like?

- The run-time view shows only the result, but all components are still present inside the container:



What is inside the container image?

- Most containers include **Free and Open Source software** (FOSS)
- When **copying and distributing** FOSS, license obligations have to be fulfilled, *e.g.*
  - **Information obligations:** License texts, legal notices, warranty disclaimer
  - **Disclosure obligations:** Source code and build instructions
  - **Licensing obligations:** Adapting company documents, licensing own development correctly if a derivative work with software under a copyleft license is created

What is the challenge with containers …

… from a **legal compliance** point of view?

- It is not obvious **what software is distributed** within the container.
  - But license obligations must be fulfilled for <u>all</u> software that is distributed.
- Public container repositories often **do not provide compliance information**.
  - But license obligations generally remain with the distributor not with the owner of the repository.

What about Containerfiles?

- Containerfiles are **scripts** from which a container engine can assemble a container image.
- Software is **downloaded** from public or private repositories.
- Containerfiles can be **distributed** instead of container images.

Who is responsible for license compliance when distributing a Containerfile?

- When the recipient of a Containerfile executes a container image build, software is **downloaded directly**.
- Who is the distributor of this software?

Who is responsible for license compliance when distributing a Containerfile?

- When the recipient of a Containerfile executes a container image build, software is **downloaded directly**.
- Who is the distributor of this software?

The person who **controls** the distribution.*

→ Distributing a Containerfile = Distributing software

* "The highest courts in Germany and the EU regularly decide that not only the physical act is relevant but also other aspects are to be considered that could lead to a situation where the third party that physically performs the legally relevant act of copying and distributing is merely considered a "tool" of the one who appears as principal or initiator." (Reference see last slide)

Who is responsible for license compliance when distributing a Containerfile?

- The person who **controls** the distribution.

  → **Distributing a Containerfile = Distributing software**

- Difficulties:
  - Repositories mostly do not contain compliance material (*e.g.* license information, source code)
  - Commands in a Containerfile may point to different software at different times (*e.g.* version "latest")

A license compliant base image

Applying the Open Source principle of **shared development** of non-differentiating technologies and services to **license obligations of container base images**.

Caren Kresse, OSADL (C.Kresse@osadl.org)

The OSADL Base Image

- **Minimal image based on a Linux distribution:**
  - Essential GNU tools, shell, C-lib, package manager, networking functionalities
- **License compliance material:**
  - Source code of all packages
  - License texts & copyright notices
  - Legal notices

The OSADL Base Image

- **Minimal image based on a Linux distribution:**
  - Essential GNU tools, shell, C-lib, package manager, networking functionalities
- **License compliance material:**
  - Source code of all packages
  - License texts & copyright notices
  - Legal notices

Using resources from the OSSelot project*

*At the moment, OSSelot data is used in the Debian trixie and Alpine v3.23 base images.

Digression:

Re-using curated OSSelot data to clear base image source packages

Caren Kresse, OSADL (C.Kresse@osadl.org)

- The **OSSelot** project (https://www.osselot.org) provides a publicly available **trusted database** with **curated compliance information** for frequently used FOSS components.
- Some manual input and review is still indispensable, but:

The reuse of curated licensing and copyright information can tremendously reduce the time required to clear a software package!

OSSelot, FOSSology and base images (1)

1. Use the OSSelot REST API to find out for which of the container's **source packages** there is **OSSelot data available** (and in which versions).
2. Upload the OSSelot version of the packages into FOSSology and **import the OSSelot data**.
   → **This clears the entire package automatically!**

OSSelot, FOSSology and base images (2)

3. Upload the container source packages into FOSSology, run **scanners** and **reuse**, referencing the corresponding OSSelot upload.
4. **Clear** the remaining files and copyrights.

Note: For more details, come to the Education track tomorrow.

The OSADL Base Image

- **Minimal image based on a Linux distribution:**
  - Essential GNU tools, shell, C-lib, package manager, networking functionalities
- **License compliance material:**
  - Source code of all packages
  - License texts & copyright notices → OSSelot
  - Legal notices

*At the moment, OSSelot data is used in the Debian trixie and Alpine v3.23 base images.

The OSADL Base Image

- **Minimal image based on a Linux distribution:**
  - Essential GNU tools, shell, C-lib, package manager, networking functionalities
- **License compliance material:**
  - Source code of all packages
  - License texts & copyright notices
  - Legal notices

→ **Immediate source code disclosure**

→ **Delayed source code disclosure**

*At the moment, OSSelot data is used in the Debian trixie and Alpine v3.23 base images.

Immediate or delayed source code disclosure

Immediate source code disclosure

- All source code and a note with legal information are included in the image.
- Available on Docker Hub: https://hub.docker.com/r/osadl/

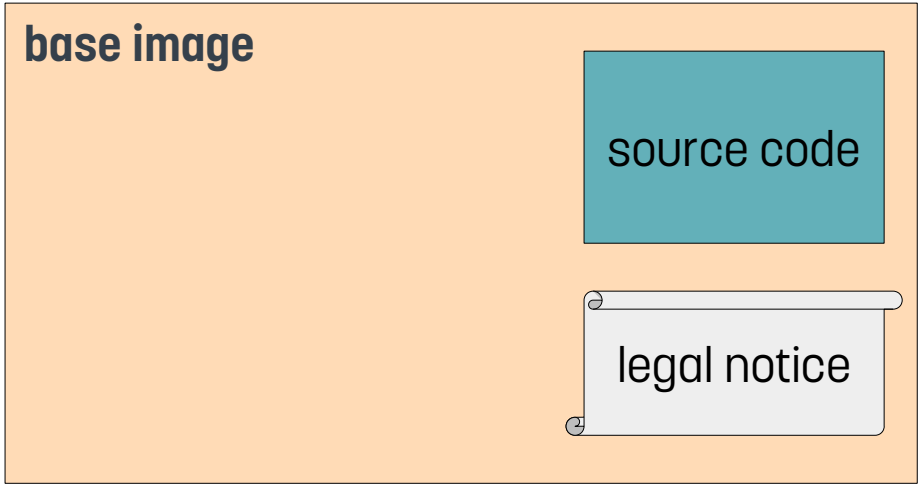
Delayed source code disclosure

- Extracted compliance material and a note with legal information and written offer are included in the image.
- The source packages including rebuild instructions for later delivery are provided separately.

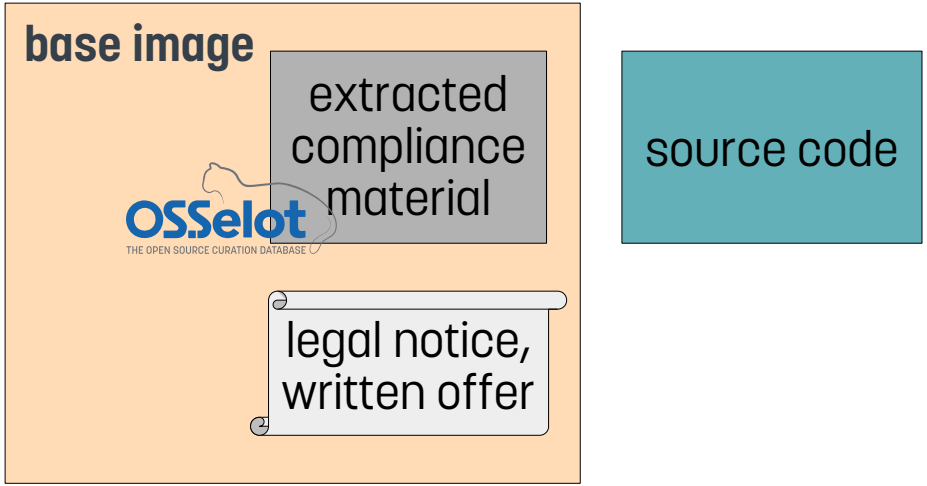
Instructions on how the base image is created and how it can be used are given in each case.

Immediate or delayed source code disclosure

Immediate source code disclosure



Delayed source code disclosure



Size of container images:

osadl/debian-docker-base-image: trixie-13.4-amd64-260318 **(423 MB)**

osadl/debian-docker-base-image: trixie-13.4-amd64-260318-bin **(110 MB)**

debian:trixie-slim **(78.6 MB)**

Variants of the OSADL Base Image

- Available at osadl.org/base-image (for OSADL members or on request) and on https://hub.docker.com/r/osadl/
- Variants (all supported LTS versions)
  (in each case for immediate or delayed source code delivery):
  - Alpine Linux, x86_64, aarch64
  - Debian, x86_64, aarch64, armhf32, i386
  - Ubuntu, x86_64, aarch64
- Additional variants can be created and made available **on request**.

Building an application on top of the OSADL Base Image

- **Customized container applications** can be built on top of the OSADL Base Image.
- For example, the Base Image can be referenced in a Containerfile:

```
FROM osadl/debian-docker-base-image:trixie-13.4-amd64-260318
```

Building an application on top of the OSADL Base Image (2)

- Software components beyond the Base Image are individual selections. License obligations must therefore be fulfilled by the distributor.
- The instructions for license compliance given with the OSADL Base Image can be used for additional layers.
- **Important: Compliance should be done by layer!**

Summary

- So far, FOSS license obligations are usually not considered when distributing containers.
- Distributing Containerfiles is w.r.t copyright law equivalent to distributing software.
- License obligations for containers must be fulfilled, no matter if distributed directly or via Containerfile.
- OSADL provides a **license compliant container base image** in different variants.
- Customized applications can be built on top of the OSADL Base Image.

References

- **Disclaimer:** The information given in this presentation does not constitute individual legal advice. It is based on a legal opinion. There is as of yet no case law with regard to this topic, and different interpretations may certainly be arguable.
- Hemel, A., 2020, Docker Containers for Legal Professionals. [pdf] Available at: https://www.linuxfoundation.jp/wp-content/uploads/2020/04/Docker-Containers-for-Legal-Professionals-Whitepaper_v4.ac_-3.pdf
[Accessed March 18, 2026]
- Jaeger, T., 2021, OSADL Legal Opinion: Are license obligations to be fulfilled when distributing Dockerfiles? Also available at DOI: 10.5033/jolts.v12i1.147

Questions or feedback ...

... please get in touch:

C.Kresse@osadl.org

osadl.org/Contact